LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Hassan Chawa | Grup Yazılım Müh. | Tarih 23 Ekim 2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Üç şartı kontrol ederim: (1) Component X, FTC30 PLC firmware'inde ve SBOM'da kayıtlı mı? (2) Sürüm 2.4, CVE'nin etkilenen aralığında mı? (3) Servis ağdan veya bakım portundan erişilebilir mi? Üçü evetse etkilidir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Evet, etkilenen araç ve hattı kontrollü şekilde güvenli duruma alırım (STO, hareketsiz). Tüm üretimi durdurmam; önce erişim yolu kısıtlanır, etkilenmeyen hatlar çalışmaya devam eder. Gerekçe: CVSS 9.8 ve fiziksel tehlike; karar risk değerlendirmesiyle belgelenir.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test ederim. Yama canlı FTC30'a doğrudan uygulanmaz; test ortamında (HIL / test rig veya yedek araç) yamanın fonksiyon ve emniyet davranışı doğrulanır. Sahaya alım kontrollü bir bakım penceresinde, geri alma (rollback) planıyla yapılır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Olabilir: kütüphane STO, güvenli durma veya LiDAR işlemeye dokunuyorsa safety validation etkilenir. Yama notları ve etki analizi ile anlarım; etkilenmişse acil durdurma, STO süresi ve zone testleri tekrarlanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Yama yoksa telafi edici önlem uygularım: bileşeni içeren servisi ağdan izole eder, gereksiz portları kapatır, erişimi jump server + MFA ile sınırlarım. Safety PLC'yi açık ağdan izole tutarım, anomali izlemesi ekler, kalan riski yetkili kişiye imzalatır ve yama takvimini belgelerim.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.